INFORME FINAL

Laboratorio de Seguridad Express

Proyecto: Tienda Modular

Fecha: 29 de octubre de 2026
Rama: seguridad
Entorno probado: PostgreSQL local aislado, HTTPS localhost y Angular local
Producción de referencia: https://tienda-modular-frontend.onrender.com/

Integrantes: no se identificaron nombres verificables en la documentación del repositorio; no se inventaron datos.

Objetivo y metodología

Se auditó el código Express/Angular, configuración, SQL y dependencias. Las pruebas de escritura se realizaron únicamente contra el contenedor local tienda-modular-postgres publicado en 127.0.0.1:5433. Se instaló una CA local con mkcert, se levantó HTTPS en 3443 y se utilizó Chrome headless para la evidencia visual. Render no fue modificado ni recibió pruebas de escritura.

Diagnóstico y correcciones

Hallazgo	OWASP	Corrección y verificación
Bearer en sessionStorage	A07	JWT firmado en cookie HttpOnly/Secure/SameSite=Strict; login 200, JWT vencido 401 y sexto fallo 429.
Falta de roles/IDOR	A01	Roles backend, registro sólo cliente y pedido asociado al usuario; cliente ajeno recibió 404.
HTTPS local parcial	A02/A04	mkcert, TLS 3443, redirección HTTP 308 y HSTS max-age=300 verificados.
CSRF basado en Bearer	A05/A07	Doble envío tm_csrf/X-CSRF-Token: 403 sin token y 201 con token.
Riesgo XSS	A05	Sin APIs HTML inseguras; Angular mostró las cargas como texto escapado.

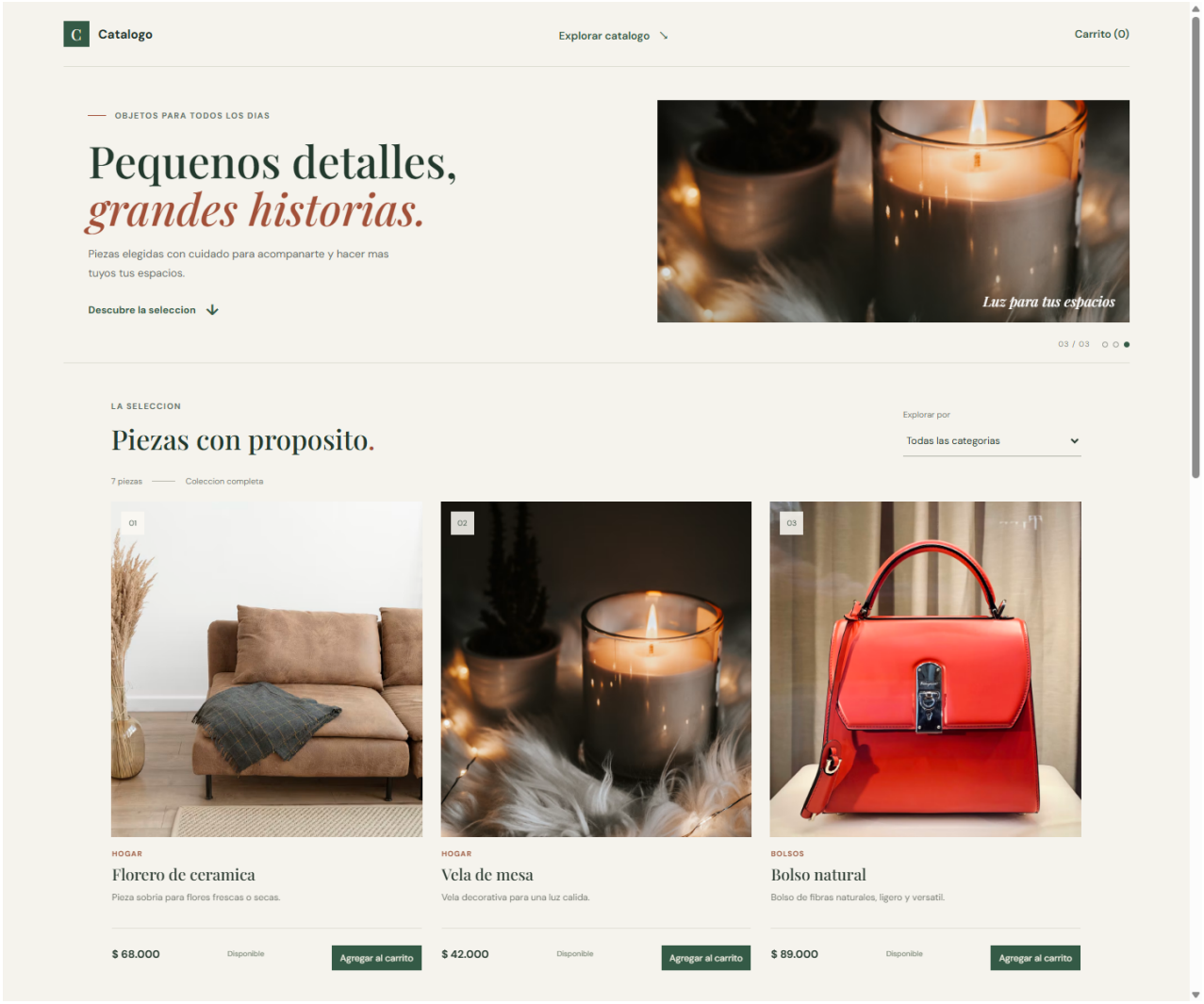
Resultados de integración HTTPS local

Prueba	Esperado	Obtenido	Resultado
login seguridad_admin_cebc6784e917	200	200	OK
HTTPS health	200	200	OK
escritura sin sesión	401	401	OK
CSRF ausente	403	403	OK
CSRF válido	201	201	OK
carga XSS almacenada para renderizado seguro	201	201	OK
registro cliente	201	201	OK
elevación de privilegios	400	400	OK
login cliente_a_mvtriace	200	200	OK
cliente no administra	403	403	OK
cantidad negativa	400	400	OK
catálogo público	200	200	OK
pedido autenticado / precio servidor	201	201	OK
login cliente_b_mvtriace	200	200	OK
IDOR pedido ajeno	404	404	OK
JWT expirado	401	401	OK
sexto login fallido	429	429	OK
CORS no autorizado	403	403	OK
Helmet/CSP	200	200	OK

Resultado: 19/19 verificaciones aprobadas. No se incluyeron tokens, cookies ni contraseñas en el PDF.

Evidencia visual XSS y catálogo

La siguiente captura fue tomada con Chrome headless sobre Angular local. La inspección de DOM confirmó que la carga de prueba aparece como <img ... onerror> y <script> codificada, no como elementos ejecutables.



Cabeceras comprobadas

CSP con default-src self, X-Content-Type-Options: nosniff y Strict-Transport-Security: max-age=300; includeSubDomains. La cadena TLS fue validada por Node con la CA local de mkcert.

OWASP, riesgos y mejora continua

Categoría	Resultado
A01	Roles, 401/403 y control IDOR 404 verificados.
A02	CORS restringido, cabeceras y HTTPS local.
A03	npm audit de producción: 0 vulnerabilidades.
A04	scrypt con sal, JWT firmado y TLS local.
A05	SQL parametrizado, CSRF y escape Angular/XSS probado.
A06	Cantidad negativa rechazada y precio obtenido desde PostgreSQL.
A07-A10	Autenticación, integridad, registro seguro de errores y validación central aplicados.

Matriz de riesgos

Riesgo	Prob.	Impacto	Tratamiento
Filtración de PostgreSQL	Media	Alto	Mitigar: rotación, mínimo privilegio y red restringida.
Fuerza bruta distribuida	Media	Medio	Mitigar: rate limit distribuido y alertas futuras.
XSS futuro	Baja	Alto	Mitigar: CSP, revisión y pruebas automatizadas.
Pedidos de invitado	Media	Medio	Aceptar temporalmente; asociar cuenta en evolución futura.
Dependencias	Media	Alto	Mitigar: audit y actualización coordinada en CI.

Respuesta a incidentes y datos personales

NIST: preparación (inventario y backups), detección (alertas y logs), contención (revocar credenciales), erradicación (rotar y eliminar filtración), recuperación (validar TLS/accesos) y lecciones aprendidas (causa raíz y controles). La aplicación trata nombre, correo, teléfono, dirección, ciudad/departamento, observaciones y pedidos; se recomienda minimización, finalidad explícita, retención definida, control de acceso y atención de derechos Ley 1581 de 2012. No se declara cumplimiento legal completo.

Conclusiones y referencias

El hallazgo principal fue el token administrativo accesible desde JavaScript. La cookie HttpOnly, el JWT de vida corta, CSRF, roles y pruebas locales reducen materialmente ese riesgo. Próximos pasos: MFA administrativa, rotación de token, logs centralizados y CI de seguridad.

Referencias: Guía_Laboratorio_Seguridad_Express.pdf; OWASP Top 10; Ley 1581 de 2012; evidencias del repositorio docs/seguridad/evidencias.